ТУСУР
TUSUR UNIVERSITY

Криптография

Управление информационной безопасностью. Лекция 2.6

10 Криптография *

Раздел включает в себя 1 категорию и 2 меры обеспечения информационной безопасности:

10.1 Средства криптографической защиты информации
Цель: Обеспечить уверенность в надлежащем и эффективном использовании криптографии для защиты конфиденциальности, подлинности (аутентичности) и/или целостности информации.

- 10.1.1 Политика использования средств криптографической защиты информации
- 10.1.2 Управление ключами

* Применение криптографических методов защиты информации осуществляется в соответствии с законодательством Российской Федерации.

Политика использования средств криптографической защиты информации

ТУСУР
TUSUR UNIVERSITY

Должна быть разработана и внедрена политика использования средств криптографической защиты информации.

При разработке политики следует учитывать следующее:

a) подход к управлению применением средств криптографической защиты информации в организации, включая главные принципы, на которых должна быть основана защита коммерческой информации;
b) определенный на основе оценки риска требуемый уровень защиты с учетом типа, стойкости и качества требуемого алгоритма шифрования;
c) использование шифрования для защиты информации, передаваемой с помощью мобильных или съемных носителей, или по линиям связи;
d) подход к управлению ключами, в том числе методы по защите криптографических ключей и восстановлению зашифрованной информации в случае утери, компрометации или повреждения ключей;
e) роли и обязанности, например, кто несет ответственность за внедрение политики и управление ключами, включая их генерацию.;
f) стандарты, которые должны быть приняты для эффективной реализации во всей организации (какое решение используется и для каких бизнес-процессов);
g) влияние использования зашифрованной информации на меры обеспечения ИБ, которые базируются на проверке содержимого (например, обнаружение вредоносного ПО).

Политика использования средств криптографической защиты информации

При внедрении политики криптографической защиты в организации следует учитывать требования законодательства и ограничения, которые могут применяться в отношении использования криптографических методов в разных странах, а также вопросы трансграничной передачи зашифрованной информации.

Средства криптографической защиты информации могут использоваться для достижения различных целей, например:

a) обеспечение конфиденциальности: использование шифрования для защиты информации ограниченного доступа как при хранении, так и при передаче;
b) обеспечение целостности и аутентичности: использование электронных подписей или кодов аутентификации сообщений для проверки подлинности или целостности информации ограниченного доступа при ее передаче и хранении;
c) обеспечение неотказуемости: использование криптографических методов для подтверждения наличия или отсутствия события или действия;
d) аутентификация: использование криптографических методов для аутентификации пользователей и других системных объектов, запрашивающих доступ к пользователям, объектам и ресурсам системы или осуществляющих операции с ними.

Политика использования средств криптографической защиты информации

Принятие решения о применении криптографических решений следует рассматривать как часть более широкого процесса оценки риска и выбора мер обеспечения ИБ. Такая оценка может затем использоваться для определения того, является ли криптографическая мера подходящей, какой тип мер следует применять, с какой целью и для каких бизнес-процессов.

Политика использования криптографических мер необходима для достижения максимальных выгод и минимизации рисков использования криптографических мер, а также во избежание ненадлежащего или неправильного их использования.

Управление ключами

Политика, определяющая использование, защиту и срок действия криптографических ключей, должна быть разработана и применяться на протяжении всего их жизненного цикла.

Политика должна включать требования к управлению криптографическими ключами на протяжении всего их жизненного цикла, включая генерацию, хранение, архивирование, получение, распространение, удаление и уничтожение ключей.

Криптографические алгоритмы, длина ключей и методы использования должны выбираться исходя из лучших практик. Надлежащее управление ключами требует безопасных процессов генерации, хранения, архивирования, извлечения, распространения, удаления и уничтожения криптографических ключей.

Все криптографические ключи должны быть защищены от модификации и потери. Кроме того, секретные и закрытые ключи нуждаются в защите от несанкционированного доступа и разглашения. Оборудование, используемое для генерации, хранения и архивирования ключей, должно быть физически защищено.

Управление ключами

Система управления ключами должна базироваться на согласованном наборе стандартов, процедур и методов обеспечения безопасности для:

a) генерации ключей для различных криптографических систем и приложений;
b) выдачи и получения сертификатов открытого ключа;
c) распределения ключей тем, кому они предназначены, в том числе порядок активации ключей при получении;
d) хранения ключей, в том числе того, как авторизованные пользователи получают доступ к ключам;
e) смены или обновления ключей, включая руководство о том, когда следует менять ключи и как это сделать;
f) действий со скомпрометированными ключами;
g) отзыва ключей, в том числе того, как ключи должны быть аннулированы или деактивированы, например, когда ключи были скомпрометированы, или когда пользователь покидает организацию (в этом случае ключи также должны быть архивированы);
h) восстановления поврежденных и утерянных ключей;
i) резервного копирования или архивирования ключей;
j) уничтожения ключей;
k) регистрации и аудита действий по управлению ключами.

Управление ключами

В политике управления ключами следует определить даты активации и деактивации ключей, чтобы ключи могли использоваться только в течение периода времени, что уменьшит вероятность их ненадлежащего использования.

В дополнение к вопросу безопасного управления секретными и закрытыми ключами следует также учитывать вопросы аутентичности открытых ключей. Процесс аутентификации достигается применением сертификатов открытых ключей, которые обычно выдаются удостоверяющим центром – признанной организацией с соответствующими реализованными мерами и процедурами для обеспечения требуемого уровня доверия.

Содержание соглашений об уровне обслуживания или договоров с внешними поставщиками криптографических услуг, например с удостоверяющим центром, должно охватывать вопросы ответственности, надежности услуг и времени реагирования на запросы.

Рассмотренные вопросы

Криптография:

- Политика использования СКЗИ

Почитать

- ГОСТ Р ИСО/МЭК 27002-2021

ТУСУР
TUSUR UNIVERSITY

Всем спасибо – все свободны,

если нет вопросов!